

Занятие 2. WEB-1

В ходе этого занятия мы довольно подробно разберём HTTP-запросы и Cookie, а также решим несколько задач по этим темам. Помимо этого будут предложены задачи для самостоятельного решения по разобранным темам (и не только).

HTTP-запросы

Общие сведения

HTTP (*HyperText Transfer Protocol*) — это протокол прикладного уровня, который используется для передачи данных между веб-сервером и клиентом. Он является основой работы интернета и обеспечивает обмен информацией между различными устройствами и приложениями. Протокол позволяет пользователям запрашивать ресурсы, такие как веб-страницы, изображения и другие файлы, с сервера на свой компьютер.

URI (*Uniform Resource Identifier*) — это уникальный идентификатор, который используется для обозначения ресурсов в интернете. Это может быть веб-страница, файл, изображение и т. д. URI состоит из нескольких частей:

1. *Схема*. Определяет тип ресурса и протокол, используемый для доступа к нему. Например, «http» для веб-страниц или «ftp» для файлов на FTP-сервере.
2. *Хост*. Указывает на сервер, на котором находится ресурс.
3. *Путь*. Описывает расположение ресурса на сервере.
4. *Параметры*. Дополнительные данные, которые могут быть переданы вместе с запросом на ресурс.

Например, URI может выглядеть так: «https://pikabu.ru/story/roma_6931851». Здесь «https» — схема, «pikabu.ru» — хост, а «story/roma_6931851» — путь.

Когда вы вводите URI в браузере, он отправляет запрос на соответствующий сервер и получает от него ответ. Этот ответ может быть страницей, файлом, изображением и т. п.. Таким образом, URI — это способ идентификации ресурсов в сети, который позволяет нам получать доступ к ним и взаимодействовать с ними.

Структура HTTP-запроса

HTTP-запрос состоит из трёх основных частей:

1. *Метод*: определяет тип действия, которое клиент хочет выполнить на сервере. Например, GET, POST, PUT, DELETE.
2. *Путь*: указывает на ресурс, к которому клиент хочет получить доступ. Например, /index.html, /images/logo.png.
3. *Заголовки*: содержат дополнительную информацию о запросе, такую как тип содержимого, кодировка, авторизация и т. д.

Каждый HTTP-запрос состоит из следующих частей:

1. *Заголовки запроса* - содержат информацию о запросе, такую как метод, URI, версия протокола и заголовки HTTP.
2. *Тело запроса* - содержит данные, которые необходимо отправить на сервер (например, форма для отправки).
3. *Статусная строка* - содержит информацию о статусе запроса и может включать в себя код состояния HTTP и сообщение.

4. *Заголовки ответа* - аналогичны заголовкам запроса, но содержат информацию об ответе сервера.
5. *Тело ответа* - содержит данные, отправленные сервером в ответ на запрос.

Пример HTTP-запроса:

```
GET /index.html HTTP/1.1
Host: example.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/98.0.4758.82 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Language: ru-RU,ru;q=0.9
Connection: close
```

Здесь метод — GET, путь — /index.html. Заголовки содержат информацию о браузере клиента, типе содержимого, языке и способе соединения.

Методы HTTP

Существует несколько методов HTTP, которые определяют тип действия, выполняемого на сервере. Используемые методы:

1. **GET** - используется для получения ресурса с сервера (например, веб-страницы).
2. **POST** - используется для отправки данных на сервер.
3. **PUT** - используется для обновления ресурса на сервере (например, обновление страницы).
4. **DELETE** - используется для удаления ресурса на сервере.
5. **HEAD** - Подобен GET, но возвращает только заголовки ответа, без тела сообщения.
6. **OPTIONS** - Запрашивает информацию о том, какие методы поддерживаются для указанного ресурса.

Это лишь некоторые из наиболее распространённых методов. Полный список методов можно найти в спецификации HTTP.

Коды состояния HTTP

Строка статуса — это часть ответа сервера, которая содержит информацию о статусе запроса. Она состоит из трёх частей: код состояния, описание кода и версия протокола. **Код состояния** — это числовое значение, которое указывает на результат запроса. Коды состояния HTTP сообщают, была ли операция успешной или нет. **Описание кода** — это текстовое объяснение кода состояния. **Версия протокола** — это версия HTTP, используемая сервером. Примеры строк статуса:

1. 200 OK - запрос выполнен успешно.
2. 404 Not Found - запрашиваемый ресурс не найден.
3. 500 Internal Server Error - на сервере произошла ошибка.

Коды состояния делятся на пять категорий:

1. 1xx - информационные ответы.
2. 2xx - успешные ответы.
3. 3xx - перенаправления.
4. 4xx - ошибки клиента.
5. 5xx - ошибки сервера.

Полный список кодов состояния можно найти в спецификации HTTP.

Практика

Задача 1. web-полигон с сайта Duckerz

Решение:

1. Откроем веб-страницу из задания во встроенном браузере Burp Suite.
2. Во вкладке Proxy/HTTP history найдём любой запрос к целевой странице, щёлкнем по нему правой кнопкой мыши и отправим во вкладку Repeater.
3. Обратимся с помощью метода GET на конечную точку /flag. Получим при этом первую часть флага.
4. Обратимся с помощью метода POST на конечную точку /flag. Получим при этом вторую часть флага.
5. Обратимся с помощью метода GET на конечную точку /flag?q=123. Получим при этом третью часть флага.
6. Соединим все части воедино и вуаля, задание решено!

Задача 2. GET aHEAD с сайта picoCTF

Решение:

1. Откроем веб-страницу из задания во встроенном браузере Burp Suite.
2. Во вкладке Proxy/HTTP history найдём любой запрос к целевой странице, щёлкнем по нему правой кнопкой мыши и отправим во вкладку Repeater.
3. Заменяем метод из запроса на метод HEAD.
4. Найдём в ответе сервера заголовок flag и заберём из него наш флаг.

Cookie

Общие сведения

HTTP является протоколом без статических данных, что означает, что он не может различать два последовательных запроса, исходящих от одного и того же компьютера, сети или пользователя. Это было основной проблемой. Из-за этого пользователь не мог поддерживать свою сессию, и если бы мы продолжили в том же духе, интернет стал бы таким же, каким он был десять лет назад, состоящим только из кучи статичных html-страниц. Никаких учетных записей пользователей, никакой настройки и т.д., а если и есть какие-то учетные записи, то для доступа к каждой странице нужно снова и снова входить в систему. Чтобы решить эту проблему, HTTP нужно было сделать с сохранением состояния. Ответом стал файл cookie. Это небольшие файлы, создаваемые веб-сайтом, который вы посещаете. Они генерируются веб-приложениями и хранятся в вашем браузере в виде пар ключ-значение. Примером может служить PHPSESSID: хуjaez1081lze23, lang: en.

Для чего нужны

В основном файлы куки позволяют собирать и хранить:

1. Данные авторизационной сессии.
2. Личные данные пользователя, включая номер телефона, адрес и данные карты.
3. Пользовательские настройки — адаптацию базовых настроек под конкретного человека.
4. Пользовательскую статистику — информацию о посещаемых сайтах, запросах и кликах.
5. Данные устройства, с которого пользователь заходил на сайт.

Виды Cookie

Не все cookie одинаковы. Они различаются по своему назначению, сроку действия и источнику.

По назначению cookie делятся на:

1. *Необходимые cookie* — обеспечивают базовую функциональность сайта. Без них многие веб-сайты просто не смогут работать корректно. Они запоминают ваши действия на странице, сохраняют содержимое корзины в интернет-магазине или данные для входа в личный кабинет.
2. *Функциональные cookie* — позволяют сайту запоминать ваши предпочтения и настройки: выбранный язык, размер шрифта, регион и т.д. Они улучшают пользовательский опыт, но не являются обязательными для работы сайта.
3. *Аналитические cookie* — собирают информацию о том, как вы используете сайт: какие страницы посещаете, сколько времени проводите на них, по каким ссылкам переходите. Эти данные помогают владельцам сайтов анализировать поведение пользователей и улучшать свои ресурсы.
4. *Рекламные cookie* — отслеживают ваши интересы на основе просмотренных страниц и показывают вам таргетированную рекламу. Именно они ответственны за то, что после просмотра холодильников в интернет-магазине, реклама этих же холодильников преследует вас на всех сайтах.

По сроку действия cookie делятся на:

1. *Сессионные cookie* — временные файлы, которые удаляются после закрытия браузера. Они помогают сайтам «запоминать» вас во время одного сеанса просмотра.
2. *Постоянные cookie* — сохраняются на вашем устройстве даже после закрытия браузера и могут действовать от нескольких дней до нескольких лет, в зависимости от настроек.

По источнику cookie делятся на:

1. *Основные cookie* — создаются непосредственно сайтом, который вы посещаете.
2. *Сторонние cookie* — устанавливаются другими доменами, например, рекламными сетями или сервисами аналитики. Именно они вызывают наибольшие опасения с точки зрения приватности, так как позволяют отслеживать ваше поведение на разных сайтах.

Практика

Задача 3. Печеньки с молочком с сайта Duckertz

Решение:

1. Откроем веб-страницу из задания в любом удобном браузере.
2. Перейдём в панель разработчика. Обычно это делается одним из двух способов: либо щёлкнуть правой кнопкой мыши по любому месту веб-страницы и выбрать пункт Исследовать элемент, либо на клавиатуре нажать клавишу F12 (иногда на ноутбуках fn+F12).
3. Перейдём во вкладку Application/Cookies и найдём там cookie username со значением anonymous.
4. Поменяем значение cookie username с anonymous на admin.
5. Обновим страницу с помощью клавиши F5 (fn+F5) или встроенной кнопки браузера.
6. На странице отобразится флаг, а это означает, что Советский спорт снова одержал большую победу!

Задача 4. Cookies с сайта picoCTF

Решение:

1. Откроем веб-страницу из задания в любом удобном браузере.
2. Перейдём в панель разработчика. Обычно это делается одним из двух способов: либо щёлкнуть правой кнопкой мыши по любому месту веб-страницы и выбрать пункт

Исследовать элемент, либо на клавиатуре нажать клавишу F12 (иногда на ноутбуках fn+F12).

3. Перейдём во вкладку Application/Cookies и найдём там cookie name со значением -1.
4. Попробуем поискать разные значения, воспользовавшись предоставляемым страницей функционалом. Заметим, что при поиске по значению snickerdoodle, которое было любезно подсказано нам на самой странице, значение cookie name меняется с -1 на 0. Пораскинув мозгами, можно сделать вывод, что все легитимные значения для поиска пронумерованы начиная с нуля и этот номер является значением cookie name.
5. Проверим нашу догадку изменив значение cookie name на 1 и обновив страницу. Действительно, запрос прошёл успешно и на странице отобразилась новая печенюшка.
6. Теперь уже совсем понятно что нужно делать. Необходимо перебрать все значения cookie name и для одного из них должен отобразиться флаг. И тут у нас есть два пути достижения цели: истинные джедаи будут перебирать все значения cookie name руками в браузере, а недостойные напишут для этой цели скрипт. Естественно я отношу себя ко второй категории.
7. Открываем любой текстовый редактор и пишем следующий скрипт на языке Python:

```
import requests
import re

url = 'http://mercury.picoctf.net:17781/check' # в этом месте будьте внимательны,
хост и порт могут меняться!!!
pattern = r'(?<=I love\s).*?(?=\s*cookies!)'

for i in range(50):
    cookie = {'name': str(i)}
    response = requests.get(url=url, cookies=cookie)
    match = re.search(pattern, response.text)
    try:
        result = match.group(0).strip()
        print(i, result)
    except:
        print(i, response.text)
```

Данный скрипт, конечно, не блещет своей надёжностью и отказоустойчивостью, но, тем не менее, помогает нам найти флаг, а вместе с тем и решить задание.

Задачи для самостоятельного решения

Задачи по теме лекции:

1. Сила воли
2. Cookie Monster Secret Recipe
3. IntroToBurp
4. level4
5. level5
6. level6
7. level7
8. level8

Лёгкие задачи не по теме лекции (в основном на инспекцию кода):

1. WebDecode
2. Unminify
3. Inspect HTML

4. Insp3ct0r
5. Пин код
6. Полёт нормальный
7. Правила
8. Умный переулок

Что ещё можно порешать:

За одну коротенькую лекцию по вебу невозможно затронуть все темы, на которые есть лёгкие задачки из категории Web. Поэтому многое вам придётся изучать самостоятельно. Для тренировки своих навыков на данном этапе отлично подойдут платформы: Duckerz, PicoCTF, Over The Wire (уровень Natas), Portswigger, web Kids 2.0 и другие подобные. Достаточно просто открыть категорию Web и начать решать задачки из неё по мере увеличения их сложности.

Полезные ссылки

Статья на Хабр по HTTP-запросам
Ссылка на скачивание Burp Suite
Статья на Хабр про Cookie с кривым переводом
Статья на SecurityLab про Cookie
Статья на Яндекс Практикум про Cookie